

Bilateral Receipt Admission: Cross-Organizational Action Provenance with Treaty-Bound DSSE

Anonymous Author(s)

Abstract

Existing supply-chain provenance attests how an artifact was built; cross-organizational agent invocations need provenance for how an action was admitted at the receiving kernel. SLSA, in-toto, Sigstore, and Rekor describe production; none attest that two parties jointly admitted an action under a treaty-bound predicate over identical canonical bytes including a continuation that links to receipt-graph state. We define a DSSE predicate type whose subject digest binds a tuple of treaty scope, ladder-intersection hash, request and outcome digests, continuation hash, and two receipt hashes under two named kernel keys, and a strict verifier with five rejection codes that distinguish noncanonical payloads, predicate-type mismatch, signer reuse, stale leases, and subject-digest mismatch. We implement the construction as a Rust runtime with a pre-dispatch admission hook that fails closed on federated-origin requests, with selective disclosure via BBS at presentation while Ed25519 remains authoritative for audit corpora. We demonstrate the construction with a three-vendor buyer-closure that replays both admitted and denied paths in the same canonical schema. The construction defeats sibling-treaty cross-receipt substitution, BBS stub-vs-real disambiguation, and error-message oracles by construction; the companion position paper defends the full polity, amendment, and Lean-attestable construction.

1 Introduction

Tool-using agents already behave like institutional actors, receiving delegated authority, calling tools across organizational boundaries, and emitting records that become accounting evidence. The weak point is provenance for cross-vendor action: existing supply-chain provenance (SLSA, in-toto, Sigstore, Rekor) attests how an artifact was *built*; agent invocations need provenance for how an action was *admitted at the receiving kernel*. No deployed primitive attests that two parties jointly admitted an action under a treaty-bound predicate over identical canonical bytes that include a continuation linking to receipt-graph state.

We close that gap with a single cryptographic construction. A bilateral DSSE envelope of predicate type `chio.bilateral-co-sign-invocation.v1` carries a subject digest computed over the canonical receipt body that binds treaty-scope hash, ladder-intersection hash, request and outcome digests, continuation hash, and the two participating kernels' receipt hashes. A strict verifier accepts the envelope iff (i) both signatures verify against signer keys that are independent and pinned in the verifier-owned trust store; (ii) the payload is canonical JSON; (iii) the statement type is in-toto and the predicate type is the strict Chiodos profile; (iv) the leases referenced by the payload are fresh against the verifier's revocation epoch; and (v) the subject digest equals the canonical hash of the bound tuple. Five rejection codes distinguish each failure class so downstream audit can identify which constitutional precondition failed.

This paper defends the bilateral-DSSE primitive on its own technical merits. A companion paper extends the construction to a polity model with Lean-attestable amendments, treaty-of-treaties composition, and political-theory framing. The present paper deliberately scopes to the cryptographic and runtime primitives that survive without that framing.

The contributions are four falsifiable artifacts:

- A DSSE predicate type and canonical subject-digest binding for bilateral cross-kernel admission, with a five-code rejection taxonomy.
- A Rust runtime with a pre-dispatch admission hook that fails closed on federated-origin requests, plus a strict bilateral verifier.
- A three-vendor buyer-closure that replays admitted and denied paths in the same canonical schema.
- A negative-result characterization: sibling-treaty cross-receipt substitution, BBS stub-vs-real disambiguation, single-lane witness compromise, and error-message oracles are rejected by construction.

2 Receipt Admission as a Primitive

Signed-evidence systems decide one of two questions. Supply-chain transparency logs (Certificate Transparency, Rekor, in-toto, SLSA) answer how an artifact was built and whether a build-time claim was published to a public log [6, 9–12]. Authorization systems (Cedar, OPA, capability OSEs) answer whether a principal may perform an action inside a single trust boundary [2, 3, 5, 8]. Neither addresses the question agent systems force: whether two organizations jointly admitted a cross-vendor action under predicates each holds independently, in a form a third-party verifier can replay over canonical bytes.

The bilateral-receipt-admission primitive is the smallest construction that answers that question. It separates four concerns:

Local enforcement. Each kernel evaluates a local predicate set against a tool-call request. The predicate set may include capability attenuation [8], information-flow gates [13], or arbitrary local policy. The local decision is recorded in a canonical receipt body signed with the kernel's Ed25519 key.

Treaty-bound co-signing. When the action crosses an organizational boundary, both kernels independently sign a DSSE envelope whose subject digest binds the two receipts plus the treaty's scope, ladder, and continuation state. The envelope is admissible only when both signatures verify, the predicate type matches, and the canonical bytes are identical at both signers.

Strict rejection. A verifier accepts only envelopes that satisfy every precondition. The rejection codes are part of the protocol so downstream audit can identify the failing precondition.

Selective disclosure at presentation. BBS group signatures [1, 4, 7] project the receipt body for presentation to a third party (regulator, auditor, counterparty) without exposing every field. Ed25519 over canonical bytes remains authoritative for audit corpora; BBS is presentation-only.

The four concerns compose: local enforcement is independent of the cosigning protocol; cosigning is independent of selective disclosure; the verifier’s rejection codes are independent of all three. A deployment can adopt them incrementally.

3 Predicate Schema and Strict Verifier

4 Formal Sketch

5 Implementation

6 Evaluation

7 Attacks Defeated by Construction

8 Related Work

9 Limitations

References

- [1] Dan Boneh, Xavier Boyen, and Hovav Shacham. 2004. Short Group Signatures. In *Advances in Cryptology - CRYPTO 2004*. 41–55. doi:10.1007/978-3-540-28628-8_3
- [2] Joseph W. Cutler, Craig Dill, Aaron Eline, Nate Foster, Karol Grosse, Mark McLaughlin, Neha Rungta, Caleb Stanford Smith, Serdar Tasiran, and Emina Torlak. 2024. Cedar: A New Language for Expressive, Fast, Safe, and Analyzable Authorization. In *Proceedings of the ACM on Programming Languages, OOPSLA*. <https://2024.splashcon.org/details/splash-2024-oopsla/25/Cedar-A-New-Language-for-Expressive-Fast-Safe-and-Analyzable-Authorization>
- [3] Darin Cuvillier, Aaron Eline, Joseph W. Cutler, Serdar Tasiran, Emina Torlak, and Neha Rungta. 2024. How We Built Cedar: A Verification-Guided Approach. In *Proceedings of the ACM International Conference on the Foundations of Software Engineering (FSE)*. <https://arxiv.org/abs/2407.01688>
- [4] ETSI. 2025. *Analysis of Selective Disclosure and Zero-Knowledge Proofs Applied to EUDI Wallet*. Technical Report TR 119 476-1 v1.3.1. European Telecommunications Standards Institute. https://www.etsi.org/deliver/etsi_tr/119400_119499/11947601/01.03.01_60/tr_11947601v010301p.pdf
- [5] Gerwin Klein, Kevin Elphinstone, Gernot Heiser, June Andronick, David Cock, Philip Derrin, Dhammika Elkaduwe, Kai Engelhardt, Rafal Kolanski, Michael Norrish, Thomas Sewell, Harvey Tuch, and Simon Winwood. 2009. seL4: Formal Verification of an OS Kernel. In *Proceedings of the 22nd ACM Symposium on Operating Systems Principles*. doi:10.1145/1629575.1629596
- [6] Ben Laurie, Emilia Messeri, and Rob Stradling. 2021. Certificate Transparency Version 2.0. RFC 9162. doi:10.17487/RFC9162
- [7] Tobias Looker, Victoria Kalos, Mike Whitehead, and Ethan Bastian. 2026. The BBS Signature Scheme. Internet-Draft draft-irtf-cfrg-bbs-signatures-10. <https://datatracker.ietf.org/doc/draft-irtf-cfrg-bbs-signatures/>
- [8] Mark S. Miller. 2006. *Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control*. Ph.D. Dissertation. Johns Hopkins University. <https://jscholarship.library.jhu.edu/bitstream/handle/1774.2/873/markm-thesis.pdf>
- [9] Secure Systems Lab. 2026. Dead Simple Signing Envelope. <https://github.com/secure-systems-lab/dsse>
- [10] Sigstore Project. 2026. Sigstore Security Model. <https://docs.sigstore.dev/about/security/>
- [11] SLSA Framework. 2026. Supply-chain Levels for Software Artifacts Specification. <https://slsa.dev/spec/latest/>
- [12] Santiago Torres-Arias, Hammad Afzali, Trishank Karthik Kuppusamy, Reza Curtmola, and Justin Cappos. 2019. in-toto: Providing Farm-to-Table Guarantees for Bits and Bytes. In *28th USENIX Security Symposium*. <https://www.usenix.org/conference/usenixsecurity19/presentation/torres-arias>
- [13] Yuhao Wu, Franziska Roesner, Tadayoshi Kohno, Ning Zhang, and Umar Iqbal. 2025. IsolateGPT: An Execution Isolation Architecture for LLM-Based Agentic Systems. In *32nd Network and Distributed System Security Symposium (NDSS)*. <https://www.ndss-symposium.org/ndss2025/>